

Scenario:

Stellar Clothing is a retail clothing company that provides customers with one-stop-shopping experience for clothing and clothing accessories (hats, shoes, belts, etc.). Established in 2024, Stellar Clothing saw exponential growth and expanded from one location to 10 and an addition of a distribution center in under two years. The company saw increase of 12 to approximately 500 employees in that time frame. The company has a security team that consists of two IT team members and one cybersecurity analyst. The team has not implemented necessary security measures to keep Stellar Clothing secure.

The main office consists of employees from across the country who remotely log in to internal systems and emails via a VPN. Employees access these systems using a username and password. Stellar Clothing does not have multi-factor authentication (MFA) enabled.

Security education, training, and awareness is conducted ad hoc. Not all new hires go through the training, and some current employees have not done the training in over a year. The material has not been updated in 11 months. The main concern for the company is phishing and social engineering attacks.

Stellar Clothing's approach to cybersecurity is ad hoc. The company does not follow a framework to implement consistent security across its systems.

Risk Assessment

1. Identify assets:

- Information assets: Customer data, payment-related information, internal communications, and operational data
- Technology assets: Cloud-based email platform, internal business systems, identity and access management systems
- People: Retail employees, distribution staff, and employees with remote access to systems

2. Identify threats:

- Phishing and social engineering attacks
- Credential theft and unauthorized system access
- Data exfiltration or misuse of customer information
- Account takeover
- Unauthorized system access

3. Identify vulnerabilities:

- Reliance on single-factor authentication
- Insufficient employee awareness of phishing indicators
- Proper monitoring of anomalous login behavior

4. Analyze risk: Due to the use of single-factor authentication and lack of employee training and awareness, the likelihood of successful phishing attacks against Stellar Clothing is high. The potential impact is high as compromised credentials could lead to unauthorized access to internal systems and resources.

5. Risk mitigation Plan:

- Implement multi-factor authentication (MFA)
- Update identity and access management policies to mandate MFA and define acceptable authentication methods, such as what you know (password), what you have (RFID card), and what you are (biometrics).
- Enhance employee security awareness and training to include indicators of phishing.
- Implement a System Information and Event Management (SIEM) system to monitor logs.

6. Implement and monitor: Stellar Clothing implements the mitigation plan by rolling out MFA across all user accounts, updating relevant security policies, and conducting employee training. The organization

continuously monitors authentication logs, phishing reports, and incident metrics to assess control effectiveness. The results are documented and communicated to appropriate parties.

Risk Appetite and Risk Tolerance

Due to the nature of the company, Stellar Clothing has a low-risk appetite for unauthorized access to systems, exposure of customer data, and regulatory compliance. This means the company is not willing to accept risks and they must be mitigated. The company is willing to accept minimal operational risk but not risks that could result in data breaches or legal penalties. As for tolerance, critical-risk events involving customer data are not tolerable, meaning risks to customer data must be mitigated. Medium-risk events may be temporarily tolerated with documented mitigation plans, and low-risk events may be accepted with management approval.

Risk Matrix

————— Impact —————→

Likelihood ↑		Insignificant	Minor	Moderate	Significant	Severe
	Certain	Low	Medium	High	Critical	Critical
	Likely	Low	Medium	Medium	High	Critical
	Possible	Low	Low	Medium	High	High
	Unlikely	Low	Low	Low	Medium	High
	Rare	Low	Low	Low	Medium	Medium

Based on the 5x5 risk matrix, the threats are prioritized as:

1. The likelihood of a phishing attack is likely. The impact would be significant. The risk is critical.
2. The likelihood of credential theft and unauthorized system access due to a successful phishing attack is certain. The impact would be significant. The risk is critical.
3. The likelihood of account takeover is likely. The impact would be significant. The risk is high.
4. The likelihood of unauthorized system access is possible. The impact would be severe. The risk is high.
5. The likelihood of data exfiltration is possible. The impact would be severe. The risk is high.

Based on the qualitative risk assessment, Stellar Clothing would focus on the critical risk. Stellar Clothing would use quantitative risk assessment to determine the cost of the risks and make a decision on how to mitigate them based on their monetary value.

Risk Register

Risk ID	Asset	Threat	Vulnerability	Likelihood	Impact	Risk Level	Risk Response/ Mitigation	Risk Owner	Status	Review Date
R-001	Employee user accounts	Phishing and social engineering attacks	Use of single-factor authentication	Likely	Significant	Critical	Implement multi-factor authentication (MFA) for all user accounts	IT Security	Planned	Six months
R-002	Employee user accounts	Credential theft and unauthorized system access	Inadequate employee awareness of phishing indicators	Certain	Significant	Critical	Conduct regular security awareness and training	HR/ IT Security	Planned	Six months
R-003	Customer data	Attack takeover	Use of single-factor authentication	Likely	Significant	High	Enforce MFA and strengthen access control policies	IT Security	Planned	Six months
R-004	Internal systems	Unauthorized system access	Insufficient monitoring of anomalous login behavior	Possible	Severe	High	Implement a security information and event management (SIEM) system	Cybersecurity Analyst	Planned	Six months
R-005	Customer information	Data exfiltration	Lack of real-time threat detection and alerting	Possible	Severe	High	Implement a SIEM, endpoint detection and response tool (XDR)	Cybersecurity Analyst	Planned	Six months

Compliance

The risk identified showed that Stellar Clothing is not in compliance with PCI DSS 4.0.1. The risks response will allow Stellar Clothing to meet PCI DSS 4.0.1 Requirements for MFA, security awareness, real-time monitoring with an Extended Detection and Response (XDR) system and log monitoring via Security information and event management (SIEM) system. The specific requirements that will be met are listed below.

Extended Detection and Response (real-time monitoring and malware detection)

Requirement 5: Protect All Systems and Networks from Malicious Software

- 5.1 Processes and mechanisms for protecting all systems and networks from malicious software are defined and understood.
 - 5.1.1: All security policies and operational procedures that are identified in Requirement 8 are: documented, kept up-to-date; in use; known to all affected parties.
 - 5.1.2: Roles and responsibilities for performing activities in Requirement 5 are documented, assigned, and understood.
- 5.2 Malicious software (malware) is prevented or detected and addressed.
 - 5.2.1: An anti-malware solution(s) is deployed on all system components, except for those system components identified in periodic evaluation per Requirement 5.2.3 that concludes the system components are not at risk from malware.
 - 5.2.2: The deployed anti-malware solution(s): detects all known types of malware; removes, blocks, or contains all known types of malware.
- 5.3 Anti-malware mechanisms and processes are active, maintained, and monitored.
 - 5.3.1: The anti-malware solution(s) is kept current via automatic updates.
 - 5.3.2: The anti-malware solution(s) performs periodic scans and active or real-time scans or performs continuous behavioral analysis of systems or processes.
 - 5.3.2.1: If periodic malware scans are performed to meet Requirement 5.3.2, the frequency of scans is defined in the entity's targeted risk analysis, which is performed according to all elements specified in Requirement 12.3.1.

Multi-factor Authentication

Requirement 8: Identify Users and Authenticate Access to System Components

- 8.1 Processes and mechanisms for identifying users and authenticating access to system components are defined and understood.
 - 8.1.1: All security policies and operational procedures that are identified in Requirement 8 are: documented, kept up-to-date; in use; known to all affected parties.
 - 8.1.2: Roles and responsibilities for performing activities in Requirement 8 are documented, assigned, and understood.
- 8.4 Multi-factor authentication (MFA) is implemented to secure access into the CDE.
 - 8.4.1: MFA is implemented for all non-console access into the CDE for personnel with administrative access.
 - 8.4.2: MFA is implemented for all non-console access into the CDE.
 - 8.4.3: MFA is implemented for all remote access originating from outside the entity's network that could access or impact the CDE.
- 8.5 Multi-factor authentication (MFA) systems are configured to prevent misuse
 - 8.5.1: MFA systems are implemented as follows: the MFA system is not susceptible to replay attacks; MFA systems cannot be bypassed by any users, including administrative users unless specifically documented, and authorized by management on an exception basis, for a limited

time period; at least two different types of authentication factors are used; success of all authentication factors is required before access is granted.

SIEM (Logging and monitoring)

Requirement 10: Log and Monitor All Access to System Components and Cardholder Data

- 10.1: Processes and mechanisms for logging and monitoring all access to system components and cardholder data are defined and understood.
 - 10.1.1: All security policies and operational procedures that are identified in Requirement 10 are: documented; keep up-to-date; in use; known to all affected parties.
 - 10.1.2: Roles and responsibilities for performing activities in Requirement 10 are documented, assigned, and understood.
- 10.2: Audit logs are implemented to support the detection of anomalies and suspicious activity, and the forensic analysis of events.
 - 10.2.1: Audit logs are enabled and active for all system components and cardholder data.
 - 10.2.1.2: Audit logs capture all actions taken by any individual with administrative access, including any interactive use of application or system accounts.
 - 10.2.1.3: Audit logs capture all access to audit logs.
 - 10.2.1.4: Audit logs capture all invalid logical access attempts.
 - 10.2.1.5: Audit logs capture all changes to identification and authentication credentials including, but not limited to: creation of new accounts; elevation of privileges; all changes, additions, or deletions to accounts with administrative access.
 - 10.2.1.6: Audit logs capture the following: all initialization of new audit logs; all starting, stopping, or pausing of the existing audit logs.
 - 10.2.1.7: Audit logs capture all creation and deletion of system-level objects.
 - 10.2.2: Audit logs record the following details for each auditable event: user identification, type of event, data and time, success and failure indication, origination of event; identity or name of affected data, system component, resource, or service (for example, name and protocol).
- 10.3 Audit logs are protected from destruction and unauthorized modifications
 - 10.3.1: Read access to audit logs files is limited to those with a job-related need.
 - 10.3.2: Audit logs files are protected to prevent modifications by individuals.
 - 10.3.3: Audit log files, including those for external-facing technologies, are promptly backed up to a secure, central, internal log server(s) or other media that is difficult to modify.
 - 10.3.4: File integrity monitoring or change-detection mechanisms is used on audit logs to ensure that existing log data cannot be changed without generating alerts.
- 10.4 Audit logs are reviewed to identify anomalies or suspicious activity
 - 10.4.1: The following audit logs are reviewed at least once daily: all security events; logs of all system components that store, process, or transmit CHD and/or SAD; logs of all critical system components; logs of all servers and system components that perform security functions (for example, network security controls, IPS/IDS).
 - 10.4.1.1: Automated mechanisms are used to perform audit log reviews
 - 10.4.2: Logs of all other system components (those not specified in Requirement 10.4.1) are reviewed periodically.
 - 10.4.2.1: The frequency of periodic log reviews for all other systems components (not defined in Requirement 10.4.1) is defined in the entity's targeted risk analysis, which is performed according to all elements specified in Requirement 12.3.1
 - 10.4.3: Exceptions and anomalies identified during the review process are addressed.
- 10.5 Audit log history is retained and available for analysis

- 10.5.1: Retain audit log history for at least 12 months, with at least the most recent three months immediately available for analysis.
- 10.6 Time-synchronization mechanisms support consistent time settings across all systems
 - 10.6.1: System clocks and time are synchronized using time-synchronization technology.
 - 10.6.2: Systems are configured to the correct and consistent time as follows: one or more designated time servers are in use; only the designated central time server(s) receives time from external sources; time received from external sources is based on International Atomic Time or Coordinated Universal Time (UTC); the designated time server(s) accept time updates only from specific industry-accepted external sources; where there is more than one designated time server, the time servers peer with one another to keep accurate time; internal systems receive time information only from designated central time server(s).
 - 10.6.3: Time synchronization settings and data are protected as follows: access to time data is restricted to only personnel with a business need; any changes to time settings on critical systems are logged, monitored, and reviewed.

Security Education Training and Awareness

Requirement 12: Support Information Security with Organizational Policies and Programs

- 12.1 A comprehensive information security policy that governs and provides direction for protection of the entity's information assets is known and current
 - 12.1.1: An overall information security policy is: established; published; maintained; disseminated to all relevant personnel, as well as to relevant vendors and business partners
 - 12.1.2: The information security policy is: reviewed at least once every 12 months; updated as needed to reflect changes to business objectives or risks to the environment.
 - 12.1.3: The security policy clearly defines information security roles and responsibilities for all personnel, and all personnel are aware of and acknowledge their information security responsibilities.
- 12.6 Security awareness education is an ongoing activity
 - 12.6.1: A formal security awareness program is implemented to make all personnel aware of the entity's information security policy and procedures, and their role in protecting the cardholder data.
 - 12.6.2: The security awareness program is: reviewed at least once every 12 months; updated as needed to address any new threats and vulnerabilities that may impact the security of the entity's cardholder data and/or sensitive authentication data, or the information provided to personnel about their role in protecting cardholder data.
 - 12.6.3: Personnel receive security awareness training as follows: upon hire and at least once every 12 months; multiple methods of communication are used; personnel acknowledge at least once every 12 months that they have read and understood the information security policy and procedures
 - 12.6.3.1: Security awareness training includes awareness of threats and vulnerabilities that could impact the security of cardholder data and/or sensitive authentication data, including but not limited to: phishing and related attacks; social engineering.
 - 12.6.3.2: Security awareness training includes awareness about the acceptable use of end-user technologies in accordance with Requirement 12.2.1.

NIST CSF crossed referenced with NIST SP 800-53r5

To manage and reduce cybersecurity risks, the security team has decided to use NIST Cybersecurity Framework (CSF) as a guide to implement its security. The security team will use NIST SP 800-53r5 for security controls, tailoring which controls to use to best fit their company.

Protect (PR): Safeguards to manage the organization's cybersecurity risks are used.

- **Identity Management, Authentication, and Access Control (PR.AA):**

- PR.AA-01: Identities and credentials for authorized users, services, and hardware are managed by the organization
 - AC-01: Policy and procedures. Establish, document, maintain, and disseminate access control policies and procedures.
 - AC-02: Account management. Manage information system accounts throughout their entire lifecycle.
 - IA-01: Policy and procedures. Develop, document, disseminate, and maintain identification and authentication policies and procedures.
 - IA-02: identification and authentication (organizational users). Uniquely identify and authenticate organizational users before granting access to systems. (Initial login)
 - IA-03: Device identification and authentication. Uniquely identify and authenticate devices before granting access to systems.
 - IA-04: Identifier management. Management of identity lifecycles (usernames, UIDs, etc.) for both human and non-human users (like service accounts or devices).
 - IA-05: Authenticator management. Manage information systems authenticators by establishing protective measures, defining expiration dates, and ensuring that users follow strict renewal and revocation procedures. (Credential strength)
 - IA-06: Authentication feedback. Obscure feedback of authentication information during the authentication process to protect the information from possible exploitation and use by unauthorized individuals.
 - IA-08: Identification and authentication (non-organizational users). Uniquely identify and authenticate non-organizational users or processes acting on behalf of non-organizational users (how you handle external entities – contractors, partners, etc.- from accessing organizational systems.)
 - IA-10: Adaptive authentication. Systems to employ adaptive authentication mechanisms. The system doesn't treat every login attempt the same; it adjust the authentication requirements based on the risk profile of the specific access request. Adaptive relies on points monitored by the SIEM, such as user behavior, location/geofencing, device health, network context, and impossible travel. (Risk-based triggers)
 - IA-11: Re-authentication. Re-authentication to be revalidated over time and risk. (locks inactive sessions)
- PR.AA-02: Identities are proofed and bound to credentials based on the context of interactions
 - IA-12: Identity proofing. Identities are proofed and bound to credentials based on the context of interactions. Verify (proof) the identity of users before issuing credentials or granting system access (e.g., HR-validated identity, government ID check, background checks).
- PR.AA-03: Users, services, and hardware are authenticated

- AC-07: Unsuccessful logon attempts. Enforce a limit of consecutive invalid logon attempts by a user during a defined time period. Once the limit is reached, either lock the account or delay the next attempt.
- AC-12: Session termination. Automatically terminate a user session after specific conditions are met (e.g., inactivity, time-of-day, explicit logout).
- IA-02: Identification and authentication (organizational users). Uniquely identify and authenticate organizational users before granting access to systems. (Initial login)
- IA-03: Device identification and authentication. Uniquely identify and authenticate devices before granting access to systems.
- IA-05: Authenticator management. Manage information systems authenticators by establishing protective measures, defining expiration dates, and ensuring that users follow strict renewal and revocation procedures. (Credential strength)
- IA-08: Identification and authentication (non-organizational users). Uniquely identify and authenticate non-organizational users or processes acting on behalf of non-organizational users (how you handle external entities – contractors, partners, etc.- from accessing organizational systems.)
- IA-10: Adaptive authentication. Systems to employ adaptive authentication mechanisms. The system doesn't treat every login attempt the same; it adjust the authentication requirements based on the risk profile of the specific access request. Adaptive relies on points monitored by the SIEM, such as user behavior, location/geofencing, device health, network context, and impossible travel. (Risk-based triggers)
- IA-11: Re-authentication. Re-authentication to be revalidated over time and risk. (locks inactive sessions)
- PR.AA-04: Identity assertions are protected, conveyed, and verified
 - IA-13: Identity providers and authorization servers. Employ identity providers (IdPs) and authorization servers to manage user, device, and non-person entity (NPE) identities, attributes, and access rights supporting authentication and authorization decisions in accordance with organization-defined policy using organization-defined mechanisms.
- PR.AA-05: Access permissions, entitlements, and authorizations are defined in a policy, managed, enforced, and reviewed, and incorporate the principles of least privilege and separation of duties
 - AC-01: Policy and procedures. Establish, document, maintain, and disseminate access control policies and procedures.
 - AC-02: Account management. Manage information system accounts throughout their entire lifecycle.
 - AC-03: Access enforcement. Enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies.
 - AC-05: Separation of duties. Separation of duties includes dividing mission or business functions and support functions among different individuals or roles.
 - AC-06: Least Privilege. Employ the principle of least privilege, allowing only authorized access for users (or processes acting on behalf of users) that are necessary to accomplish assigned organizational tasks.
 - AC-10: Concurrent session control. Organizations may define the maximum number of concurrent sessions for system accounts globally, by account type, by account, or any combination thereof. It does not, however, address concurrent sessions by single users via multiple system accounts.
 - AC-16: Security and privacy attributes. Requires the system to associate security attributes (labels or metadata) and privacy attributes with information in storage, in

process, and in transit. The system then uses these attributes to enforce security policies.

- AC-17: Remote access. Establish and document usage restrictions, configuration/connection requirements, and implementation guidance for each type of remote access allowed; authorize each type of remote access to the system prior to allowing such connections.
- AC-18: Wireless access. Establish configuration requirements, connection requirements, and implementation guidance for each type of wireless access; authorize each type of wireless access to the system prior to allowing such connections.
- AC-19: Access control for mobile devices. Establish configuration requirements, connection requirements, and implementation guidance for organization-controlled mobile devices, to include when such devices are outside of controlled areas; authorize the connection of mobile devices to organizational systems.
- AC-24: Access control decisions. Establish procedures, implement mechanisms to ensure organization-defined access control decisions are applied to each access request prior to access enforcement.
- IA-13: Identity providers and authorization servers. Employ identity providers (IdPs) and authorization servers to manage user, device, and non-person entity (NPE) identities, attributes, and access rights supporting authentication and authorization decisions in accordance with organization-defined policy using organization-defined mechanisms.

- **Awareness and Training (PR.AT):**

- PR.AT-01: Personnel are provided with awareness and training so that they possess the knowledge and skills to perform general tasks with cybersecurity risks in mind
 - AT-01: Policy and procedures. Establish, document, maintain, and disseminate access security awareness and training policies and procedures.
 - AT-02: Literacy training and awareness. Provide basic cybersecurity awareness training to all information system users (including managers, senior executives, and contractors) to ensure they understand the risks and their responsibilities. Includes new user training and periodic current user training.
 - AT-03: Role-based training. Provide role-based security and privacy training to personnel, update role-based training content and incorporate lessons learned.
- PR.AT-02: Individuals in specialized roles are provided with awareness and training so that they possess the knowledge and skills to perform relevant tasks with cybersecurity risks in mind
 - AT-03: Role-based training. Provide role-based security and privacy training to personnel, update role-based training content and incorporate lessons learned.

- **Platform Security (PR.PS):**

- PR.PS-04: Log records are generated and made available for continuous monitoring
 - AU-02: Event logging. Identify the types of events that the system is capable of logging in support of the audit function; coordinate the event logging function; specify event types for logging within the system; provide a rationale for why the event types selected for logging are deemed adequate; review and update the event types selected for logging.
 - AU-03: Content of audit records. Ensure that audit records contain information the establishes the following: what type of event occurred; when the event occurred; where the event occurred; source of the event; outcome of the event; identity of any individuals, subjects, or objects/entities associated with the event.
 - AU-06: Audit record review, analysis, and reporting. Review and analyze system audit records for a defined frequency for indications of inappropriate or unusual activity and

the potential impact of the inappropriate or unusual activity. Report findings and adjust the level of audit record review, analysis, and reporting within the system when there is a change in risk based on law enforcement information, intelligence information, or other credible sources of information.

- AU-07: Audit record reduction and report generation. Provide and implement an audit record reduction and report generation capability that: supports on-demand audit record review, analysis, and reporting requirements and after-the-fact investigations of incidents; do not alter the original content or time ordering of audit records.
- AU-11: Audit record retention. Retain audit records for an organization-defined time period to provide support for after-the-fact investigations of incidents and to meet regulatory and organizational information retention requirements.
- AU-12: Audit record generation. Provide audit record generation capability for the event types the system is capable of auditing on organization-defined system components; allow authorized personnel or roles to select the event types that are to be logged by specific components of the system; generate audit records for the event types defined that include the audit record content defined in AU-03. The event types specified in AU-2d are the event types for which audit logs are to be generated and are a subset of all event types for which the system can generate audit records.
- SA-15(13): Log records are generated and made available for continuous monitoring.

Detect (DE): Possible cybersecurity attacks and compromises are found and analyzed

- **Continuous Monitoring (DE.CM):** Assets are monitored to find anomalies, indicators of compromise, and other potentially adverse events
 - DE.CM-01: Networks and network services are monitored to find potentially adverse events
 - AC-02: Account management. Manage information system accounts throughout their entire lifecycle.
 - AU-12: Audit record generation. Provide audit record generation capability for the event types the system is capable of auditing on organization-defined system components; allow authorized personnel or roles to select the event types that are to be logged by specific components of the system; generate audit records for the event types defined that include the audit record content defined in AU-03. The event types specified in AU-2d are the event types for which audit logs are to be generated and are a subset of all event types for which the system can generate audit records.
 - CA-07: Continuous monitoring. Develop a system-level continuous monitoring strategy and implement continuous monitoring in accordance with the organization-level continuous monitoring strategy the includes: establishing system-level metrics to be monitored; establishing the frequency for monitoring and assessment of control effectiveness; ongoing control assessments in accordance with the continuous monitoring strategy; ongoing monitoring of system and organization-defined metrics in accordance with the continuous monitoring strategy; correlation and analysis of information generated by control assessments and monitoring; response actions to address results of the analysis of control assessment and monitoring information; reporting the security and privacy status of the system to organization-defined personnel or roles.
 - CM-03: Configuration change control. Determine and document the types of changes to the system that are configuration-controlled; review proposed configuration-controlled changes to the system and approve or disapprove such changes with explicit consideration for security and privacy impact analysis; document configuration change

decisions associated with the system; implement approved configuration-controlled changes to the system; retain records of configuration-controlled changes to the system for organization-defined time period; monitor and review activities associated with configuration-controlled changes to the system; coordinate and provide oversight for configuration change control activities through an organization-defined configuration change control environment the convenes organization-defined frequency, organization-defined configuration change conditions.

- SC-05: Denial-of-serve protection. Protect against/limit the effects of the following types of denial-of-service events: organization-defined types of denial-of-service events. Employ the following controls to achieve the denial-of-service objective: organization-defined controls by type of denial-of-service event.
- SC-07: Boundary protection. Monitor and control communications at the external managed interfaces to the system and at key internal managed interfaces within the system; implement subnetworks for publicly accessible system components that are physically, logically separated from internal organizational networks; connect to external networks or systems only through managed interfaces consisting of boundary protection devices arranged in accordance with an organizational security and privacy architecture.
- SI-04: System monitoring. Monitor systems to detect: attacks and indicators of potential attacks; unauthorized local, network, and remote connections; identify unauthorized use of the system; invoke internal monitoring capabilities or deploy monitoring devices; analyze detected events and anomalies; adjust the level of system monitoring activity when there is a change in risk; obtain legal opinion regarding system monitoring activities; provide organization-defined system monitoring information to organization-defined personnel or roles as needed or organization-defined frequency.
- DE.CM-09: Computing hardware and software, runtime environments, and their data are monitored to find potentially adverse events.
 - AC-04: Information flow enforcement. Enforce approved authorizations for controlling the flow of information within the system and between connected systems based on organization-defined flow control policies.
 - AC-09: Previous logon notification. Notify user, upon successful logon to the system, of the date and time of the last logon.
 - AU-12: Audit record generation. Provide audit record generation capability for the event types the system is capable of auditing on organization-defined system components; allow authorized personnel or roles to select the event types that are to be logged by specific components of the system; generate audit records for the event types defined that include the audit record content defined in AU-03. The event types specified in AU-2d are the event types for which audit logs are to be generated and are a subset of all event types for which the system can generate audit records.
 - CA-07: Continuous monitoring. Develop a system-level continuous monitoring strategy and implement continuous monitoring in accordance with the organization-level continuous monitoring strategy the includes: establishing system-level metrics to be monitored; establishing the frequency for monitoring and assessment of control effectiveness; ongoing control assessments in accordance with the continuous monitoring strategy; ongoing monitoring of system and organization-defined metrics in accordance with the continuous monitoring strategy; correlation and analysis of information generated by control assessments and monitoring; response actions to address results of the analysis of control assessment and monitoring information;

reporting the security and privacy status of the system to organization-defined personnel or roles.

- CM-03: Configuration change control. Determine and document the types of changes to the system that are configuration-controlled; review proposed configuration-controlled changes to the system and approve or disapprove such changes with explicit consideration for security and privacy impact analysis; document configuration change decisions associated with the system; implement approved configuration-controlled changes to the system; retain records of configuration-controlled changes to the system for organization-defined time period; monitor and review activities associated with configuration-controlled changes to the system; coordinate and provide oversight for configuration change control activities through an organization-defined configuration change control environment that convenes organization-defined frequency, organization-defined configuration change conditions.
- CM-06: Configuration settings. Establish and document configuration settings for components employed within the system that reflect the most restrictive mode consistent with operational requirements using organization-defined common secure configurations; implement the configuration settings; identify, document, and approve any deviations from established configuration settings for organization-defined system components based on organization-defined operation requirements; monitor and control changes to the configuration settings in accordance with organizational policies and procedures.
- CM-10: Software usage restrictions. Use software and associated documentation in accordance with contract agreements and copyright laws; track the use of software and associated documentation protected by quantity licenses to control copying and distribution; control and document the use of peer-to-peer file sharing technology to ensure that this capability is not used for the unauthorized distribution, display, performance, or reproduction of copyrighted work.
- CM-11: User-installed software. Establish organization-defined policies governing the installation of software by users; enforce software installation policies through the following methods: organization-defined methods; monitor policy compliance organization-defined frequency.
- SC-35: External malicious code identification. Include system components that proactively seek to identify network-based malicious code or malicious websites.
- SI-04: System monitoring. Monitor the system to detect: attacks and indicators of potential attacks in accordance with the following monitoring objectives: organization-defined monitoring objectives; identify unauthorized use of the system through the following techniques and methods: organization-defined techniques and methods; invoke internal monitoring capabilities or deploy monitoring devices: strategically within the system to collect organization-determined essential information, at ad hoc locations within the system to track specific types of transactions of interest to the organization; analyze detected events and anomalies; adjust the level of system monitoring activity when there is a change in risk to organizational operations and assets, individuals, other organizations, or the Nation; obtain legal opinion regarding system monitoring activities; provide organization-defined system monitoring information to organization-defined personnel or roles: as needed, organization-defined frequency.
- SI-07: Software, firmware, and information integrity. Employ integrity verification tools to detect unauthorized changes to the following software, firmware, and information:

organization-defined software, firmware, and information; take the following actions when unauthorized changes to the software, firmware, and information are detected: organization-defined actions.

- **Adverse Event Analysis (DE.AE):** Anomalies, indicators of compromise, and other potentially adverse events are analyzed to characterize the events and detect cybersecurity incidents
 - DE.AE-02: Potentially adverse events are analyzed to better understand associated activities
 - AU-06 : Audit record review, analysis, and reporting. Review and analyze system audit records for a defined frequency for indications of inappropriate or unusual activity and the potential impact of the inappropriate or unusual activity. Report findings and adjust the level of audit record review, analysis, and reporting within the system when there is a change in risk based on law enforcement information, intelligence information, or other credible sources of information.
 - CA-07: Continuous monitoring. Develop a system-level continuous monitoring strategy and implement continuous monitoring in accordance with the organization-level continuous monitoring strategy the includes: establishing system-level metrics to be monitored; establishing the frequency for monitoring and assessment of control effectiveness; ongoing control assessments in accordance with the continuous monitoring strategy; ongoing monitoring of system and organization-defined metrics in accordance with the continuous monitoring strategy; correlation and analysis of information generated by control assessments and monitoring; response actions to address results of the analysis of control assessment and monitoring information; reporting the security and privacy status of the system to organization-defined personnel or roles.
 - IR-04: Incident handling. Implement an incident handling capability for incidents that is consistent with the incident response plan and includes preparation, detection and analysis, containment, eradication, and recovery; coordinate incident handling activities with contingency planning activities; incorporate lessons learned from ongoing incident handling activities into incident response procedures, training, and testing, and implement the resulting changes accordingly; ensure the rigor, intensity, scope, and results of incident handling activities are comparable and predictable across the organization.
 - SI-04: System monitoring. Monitor the system to detect: attacks and indicators of potential attacks in accordance with the following monitoring objectives: organization-defined monitoring objectives; identify unauthorized use of the system through the following techniques and methods: organization-defined techniques and methods; invoke internal monitoring capabilities or deploy monitoring devices: strategically within the system to collection organization-determined essential information, at ad hoc locations within the system to track specific types of transactions of interest to the organization; analyze detected events and anomalies; adjust the level of system monitoring activity when there is a change in risk to organizational operations and assets, individuals, other organizations, or the Nation; obtain legal opinion regarding system monitoring activities; provide organization-defined system monitoring information to organization-defined personnel or roles: as needed, organization-defined frequency.
 - DE.AE-03: Information is correlated from multiple sources
 - AU-06: Audit record review, analysis, and reporting. Review and analyze system audit records for a defined frequency for indications of inappropriate or unusual activity and the potential impact of the inappropriate or unusual activity. Report findings and adjust

the level of audit record review, analysis, and reporting within the system when there is a change in risk based on law enforcement information, intelligence information, or other credible sources of information.

- CA-07: Continuous monitoring. Develop a system-level continuous monitoring strategy and implement continuous monitoring in accordance with the organization-level continuous monitoring strategy the includes: establishing system-level metrics to be monitored; establishing the frequency for monitoring and assessment of control effectiveness; ongoing control assessments in accordance with the continuous monitoring strategy; ongoing monitoring of system and organization-defined metrics in accordance with the continuous monitoring strategy; correlation and analysis of information generated by control assessments and monitoring; response actions to address results of the analysis of control assessment and monitoring information; reporting the security and privacy status of the system to organization-defined personnel or roles.
- PM-16: Threat awareness program. Implement a threat awareness program that includes a cross-organization information-sharing capability for threat intelligence.
- IR-04: Incident handling. Implement an incident handling capability for incidents that is consistent with the incident response plan and includes preparation, detection and analysis, containment, eradication, and recovery; coordinate incident handling activities with contingency planning activities; incorporate lessons learned from ongoing incident handling activities into incident response procedures, training, and testing, and implement the resulting changes accordingly; ensure the rigor, intensity, scope, and results of incident handling activities are comparable and predictable across the organization.
- IR-05: Incident monitoring. Track and document incidents.
- IR-08: Incident response plan. Develop an incident response plan that: provides the organization with a roadmap for implementing its incident response capability, describes the structure and organization of the incident response capability, provides a high-level approach for how the incident response capability fits into overall organization, meets the unique requirements of the organization, which relate to mission, size, structure and functions, defines reportable incidents; provides metrics for measuring the incident response capability within the organization, defines the resources and management support needed to effectively maintain and mature an incident response capability, addresses the sharing of incident information, reviewed and approved by organization-defined personnel or roles for organization-defined frequency, explicitly designates responsibility for incident response to organization-defined entities, personnel, or roles; distribute copies of the incident response to organization-defined incident response personnel; update the incident response plan to address system and organizational changes or problems encountered during plan implementation, execution, or testing; communicate incident response plan changes to organization-defined incident response personnel (identified by name and/or role) and organizational elements; protect the incident response plan from unauthorized disclosure and modification.
- SI-04: System monitoring. Monitor the system to detect: attacks and indicators of potential attacks in accordance with the following monitoring objectives: organization-defined monitoring objectives; identify unauthorized use of the system through the following techniques and methods: organization-defined techniques and methods; invoke internal monitoring capabilities or deploy monitoring devices: strategically within

the system to collection organization-determined essential information, at ad hoc locations within the system to track specific types of transactions of interest to the organization; analyze detected events and anomalies; adjust the level of system monitoring activity when there is a change in risk to organizational operations and assets, individuals, other organizations, or the Nation; obtain legal opinion regarding system monitoring activities; provide organization-defined system monitoring information to organization-defined personnel or roles: as needed, organization-defined frequency.

- DE.AE-04: The estimated impact and scope of adverse events are understood
 - PM-09: Risk management strategy. Develops a comprehensive strategy to manage: security risk to organizational operations and assets, individuals, other organizations associated with the operation and use of organizational systems, privacy risk to individuals resulting from the authorized processing of personally identifiable information; implement the risk management strategy consistently across the organization; review and update the risk management strategy for organization-defined frequency or as required, to address organizational changes.
 - PM-11: Mission/business process definition. Define organizational mission and business processes with consideration for information security and privacy and the resulting risk to organizational operations, organizational assets, individuals, other organizations, the Nation; determine information protection and personally identifiable information processing needs arising from the defined mission and business processes; review and revise the mission and business process for organization-defined frequency.
 - PM-18: Privacy program plan. Develop and disseminate an organization-wide privacy program plan that provides an overview of the agency's privacy program and: includes a description of the structure of the privacy program and the resources dedicated to the privacy program, provides an overview of the requirements for the privacy program and a description of the privacy program management controls and common controls in place or planned for meetings those requirements, includes the role of the senior agency official for privacy and the identification and assignment of roles of other privacy officials and staff and their responsibilities, describes management commitment, compliance, and the strategic goals and objectives of the privacy program, reflects coordination among organizational entities responsible for the different aspects of privacy, is approved by a senior official with responsibility and accountability for the privacy risk being incurred to organizational operations (including mission, functions, image, and reputation), organizational assets, individuals, other organizations, and the Nation; update the plan for organization-defined frequency and to address changes in federal privacy laws and policy and organizational changes and problems identified during plan implementation or privacy control assessments.
 - PM-28: Risk framing. Identify and document: assumptions affecting risk assessments, risk responses, and risk monitoring, constraints affecting risk assessments, risk responses, and risk monitoring, priorities and trade-offs considered by the organization for managing risk, organizational risk tolerance; distribute the results of risk framing activities to organization-defined personnel; review and update risk framing considerations for organization-defined frequency.
 - PM-30: Supply chain risk management strategy. Develop an organization-wide strategy for managing supply chain risks associated with the development, acquisition, maintenance, and disposal of systems, system components, and system services; implement the supply chain risk management strategy consistently across the

organization; review and update the supply chain risk management strategy on organization-defined frequency or as required, to address organizational changes.

- DE.AE-06: Information on adverse events is provided to authorized staff and tools
 - IR-04: Incident handling. Implement an incident handling capability for incidents that is consistent with the incident response plan and includes preparation, detection and analysis, containment, eradication, and recovery; coordinate incident handling activities with contingency planning activities; incorporate lessons learned from ongoing incident handling activities into incident response procedures, training, and testing, and implement the resulting changes accordingly; ensure the rigor, intensity, scope, and results of incident handling activities are comparable and predictable across the organization.
 - PM-15: Security and privacy groups and associations. Establish and institutionalize contact with selected groups and associations within the security and privacy communities: to facilitate ongoing security and privacy education and training for organizational personnel, to maintain currency with recommended security and privacy practices, techniques, and technologies, and to share current security and privacy information, including threats, vulnerabilities, and incidents.
 - PM-16: Threat awareness program. Implement a threat awareness program that includes a cross-organization information-sharing capability for threat intelligence.
 - RA-10: Threat hunting. Establish and maintain a cyber threat hunting capability to: search for indicators of compromise in organizational systems, detect, track, and disrupt threats that evade existing controls; employ the threat hunting capability for organization-defined frequency.